UNIT 1 · TOPIC 1.1

Understanding Social Engineering

Quiz, Answer Key

Teacher answer key, 9 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. A teacher receives an email from "do-not-reply@g00gle.com" asking them to click a link to approve a student's document-access request. Which detail is the strongest indicator that this message is a phishing attempt?

- ○ A. The email mentions a student by relationship rather than by name
- **● B. The sender domain "g00gle.com" substitutes zeros for the letter O in "google"**
- ○ C. The email was sent during school hours
- ○ D. The subject line uses an exclamation point

Correct answer: B

Why: A lookalike domain that swaps characters to imitate a trusted brand (typosquatting) is one of the most reliable technical indicators of phishing, since legitimate organizations don't send mail from spoofed domains.

*Why the others are wrong: **A**, Vague references to a "student" without a name are a soft social-engineering cue but far less definitive than a forged domain. **C**, Timing alone says nothing about legitimacy; plenty of real institutional email arrives during school hours. **D**, Urgent punctuation is a manipulation tactic, not a technical indicator, students often overweight tone and underweight the sender address.*

2. An attacker calls an employee, claims to be from the IT helpdesk, and references the employee's manager by name before asking for a password reset. Which social engineering tactic is this?

- **● A. Pretexting**
- ○ B. Tailgating
- ○ C. Baiting
- ○ D. Phishing

Correct answer: A

Why: Pretexting involves inventing a fabricated scenario or identity, here, a fake IT role bolstered by real-sounding detail, to build false trust and extract information over a direct interaction such as a phone call.

*Why the others are wrong: **B**, Tailgating is physically following someone through a secured door, not a phone-based ruse. **C**, Baiting lures victims with an enticing physical or digital item (like a USB drive), not an invented identity. **D**, Phishing specifically refers to deceptive messages, typically email, rather than a live phone impersonation.*

3. A worker badges into a secure office building, holding the door open for a person carrying boxes who has no visible ID badge. What social engineering risk does this scenario illustrate?

- ○ A. Quid pro quo
- ○ B. Vishing
- ○ C. Whaling
- **● D. Tailgating**

Correct answer: D

Why: Tailgating (or piggybacking) is gaining unauthorized physical access by following an authorized person through a secured entry point, exploiting politeness rather than a technical flaw.

*Why the others are wrong: **A**, Quid pro quo involves offering a service in exchange for information or access, not simply following someone through a door. **B**, Vishing is voice-based phishing over phone calls, unrelated to physical entry. **C**, Whaling is phishing targeted specifically at senior executives, not a building-access scenario.*

4. In the phishing email scenario, the message states: "Research shows that the faster teachers respond to students' document-sharing requests, the more likely students are to submit assignments on time." Why does this sentence make the email more persuasive?

○ A. It explains the technical steps required to share a document

○ B. It proves the sender is affiliated with an educational research organization

● C. It cites a believable-sounding justification that pressures the teacher to act quickly without verifying the request

○ D. It confirms the student's identity to the teacher

Correct answer: C

Why: This sentence manufactures false urgency by framing inaction as harmful to students, exploiting the teacher's sense of responsibility to short-circuit careful verification, a classic influence tactic in social engineering.

*Why the others are wrong: **A**, The sentence is about urgency and consequence, not instructions. **B**, An unverified claim in an email proves nothing about the sender's actual affiliation; that's exactly the point of the manipulation. **D**, Nothing in that sentence identifies any specific student; it speaks only in generalities.*

5. An attacker leaves a USB drive labeled "Q4 Salary Review, Confidential" in an office break room. Why is this tactic likely to succeed in getting an employee to plug it in?

○ A. It requires the employee to enter a password before the attack works

○ B. It directly exploits a software vulnerability without any user action

○ C. It relies on the employee already trusting the attacker personally

● D. It exploits curiosity and the perceived value of confidential information to override caution

Correct answer: D

Why: Baiting works by dangling something the target wants, here, sensitive salary information, so curiosity or self-interest overrides normal caution about unknown devices.

*Why the others are wrong: **A**, No password entry is needed for a USB-based baiting attack to execute. **B**, Baiting requires the victim to take an action (plugging in the drive); it isn't an automatic exploit. **C**, Baiting works precisely because it doesn't require any prior relationship with the attacker.*

6. If the teacher in the scenario had clicked the link and entered their school login credentials on the resulting page, what is the most likely organizational impact?

○ A. The teacher's device is permanently disconnected from the network

○ B. The school's email server automatically resets all passwords

● C. The attacker gains access to the teacher's account and any systems or data it can reach

○ D. No impact occurs unless the teacher also opens an attachment

Correct answer: C

Why: Credential harvesting through a fake login page gives the attacker working credentials, enabling account takeover and lateral access to whatever data, email, or shared systems that account can reach, the central impact social engineering attacks are designed to produce.

*Why the others are wrong: **A**, Compromise typically grants access rather than cutting off connectivity. **B**, There is no automatic system-wide reset triggered by an individual phishing click. **D**, Credential theft itself is the harmful action; no separate attachment is required for the impact described.*

7. A school IT administrator is documenting the phishing incident with the teacher's email for a post-incident report. Which combination of evidence most strongly supports classifying this as a targeted phishing attempt rather than generic spam?

○ A. The email contained no links and only requested a reply

○ B. The email was sent to one teacher and used formal language

● **C. The email used a spoofed lookalike domain, referenced a plausible school workflow (document sharing), and created urgency tied to student outcomes**

○ D. The email was flagged by the spam filter before the teacher saw it

Correct answer: C

Why: Targeted phishing is distinguished from generic spam by the convergence of multiple deliberate elements: domain spoofing for credibility, a pretext relevant to the victim's actual role and context, and engineered urgency, together these show intentional tailoring rather than a mass, indiscriminate blast.

*Why the others are wrong: **A**, Absence of a link doesn't indicate targeting and is in fact inconsistent with this scenario, which centers on a malicious link. **B**, Single-recipient delivery and formal tone alone are weak signals; both legitimate and generic spam emails can share these traits. **D**, Being caught by a spam filter says nothing about how targeted the message was, it's an outcome of delivery, not evidence of intent.*

8. A security awareness trainer is choosing which influence principle to emphasize when teaching staff to resist pretexting calls that impersonate IT support and reference real employee names. Which principle should be prioritized, and why?

○ A. Scarcity, the call implies a limited-time offer the target doesn't want to miss

● **B. Authority, attackers borrow the credibility of a trusted role (IT) combined with insider-sounding detail to suppress the target's instinct to verify**

○ C. Liking, the attacker spends time building a personal friendship before asking for anything

○ D. Social proof, the attacker claims many other employees have already complied

Correct answer: B

Why: Impersonating IT support exploits authority bias: people are conditioned to comply with requests from perceived organizational power or technical expertise, and pairing that with accurate insider details (a manager's name) further suppresses the instinct to independently verify the caller's identity.

*Why the others are wrong: **A**, Scarcity relies on urgency around limited availability, which isn't the mechanism described in an IT-impersonation pretext. **C**, Pretexting calls are typically brief and transactional, not built on cultivated rapport over time. **D**, No claim about other employees' behavior is present in this scenario; the leverage comes from role authority, not peer comparison.*

9. A district is updating its incident-response checklist after several tailgating and pretexting incidents. Which checklist addition would most directly reduce risk across both attack types, given that they exploit different channels (physical vs. verbal)?

○ A. A monthly password rotation policy

○ B. A stronger spam filter on the email gateway

○ C. Mandatory multi-factor authentication on all cloud accounts

● **D. A policy requiring independent verification of any unscheduled request for access or information, regardless of how it arrives**

Correct answer: D

Why: Tailgating and pretexting both exploit human trust and the absence of verification rather than a technical weakness, so the common mitigation that addresses both is a verification-first culture, confirming identity or authorization independently before granting physical access or information, regardless of the channel the request comes through.

*Why the others are wrong: **A**, Password rotation is unrelated to either physical access control or verbal social engineering and doesn't address the root behavioral vulnerability. **B**, Spam filtering only addresses email-based threats and does nothing for in-person tailgating or phone-based pretexting. **C**, MFA protects account logins specifically; it doesn't stop someone from following an employee through a physical door or verbally extracting information.*